

OFFSEC

CAPTURA DE INFORMAÇÕES



3

LISTA DE FIGURAS

Figura 1 - Whois	8
Figura 2 – DNS.....	15
Figura 3 – Shodan.....	16
Figura 4 – thehasvester.....	17
Figura 5 – Maltego	19
Figura 6 – FOCA	20

EMANIP

LISTA DE QUADROS

Quadro 1 – Google hacking.....	12
--------------------------------	----

EMENDAS

SUMÁRIO

CAPTURA DE INFORMAÇÕES.....	5
1 INTRODUÇÃO	5
2 CONSULTANDO WHOIS.....	7
2.1 Presença web.....	7
2.1.1 Mídias sociais.....	10
3 GOOGLE HACKING E DNS.....	12
4 SHODAN	15
REFERÊNCIAS.....	21

CAPTURA DE INFORMAÇÕES

1 INTRODUÇÃO

Information gathering é o processo de identificação, descoberta e obtenção de informações que podem ter relevância para o pentest. Abrange uma ampla variedade de tarefas, objetivos e resultados. O processo de coleta de informações é crucial para o sucesso da maioria dos pentests, especialmente testes de caixa preta e caixa cinza, pois fornece ao testador dados potencialmente acionáveis em seu alvo. Esses dados podem acabar moldando ataques específicos de certas maneiras ou solicitar ao testador que reconsidere sua estratégia geral de ataque. Atacar um alvo diretamente, sem coletar primeiro as informações, dificultará o alcance de todos os objetivos do pentest ou poderá resultar em falha total.

No entanto, é importante observar que nem todas as informações coletadas serão úteis. É difícil prever que tipo de informação será relevante até você aprender mais sobre seu objetivo, que é aquele que o processo de coleta de informações deve alcançar. Portanto, muitas vezes, você precisará vasculhar uma grande quantidade de dados e identificar o que é e o que não é relevante para suas operações de pentest.

Open Source Intelligence (OSINT) é uma informação acionável que foi coletada de fontes disponíveis gratuita e publicamente. O tipo de informação que pode ser considerada OSINT não é algo que uma organização ou outra entidade possa razoavelmente esperar manter em sigilo. Qualquer pessoa, independentemente da afiliação ou autorização, pode obter essas informações sem entrar em conflito com nenhuma lei ou regulamento. Isso torna o OSINT valioso para as fases preliminares de um pentest, em que a discrição é desejada. Afinal, o processo de pentest deve refletir o processo de ataque do mundo real; atacantes habilidosos tentarão reunir o máximo de informações, correndo o menor número possível de riscos.

Existem muitas fontes potenciais de OSINT e a maioria está conectada à Internet. Alguns exemplos incluem:

- Informações de registro nos bancos de dados Whois.
- O site público da organização de destino.

- Quaisquer sites adicionais que possam estar relacionados à organização de destino.
- Os perfis de mídia social de uma organização de destino.
- Os perfis de mídia social de indivíduos associados à organização de destino.
- Anúncios de emprego em quadros de empregos.
- Resultados de pesquisa do Google.
- Blogs on-line, artigos de notícias etc.
- Informações coletadas na consulta de servidores DNS públicos.
- Registros do servidor de e-mail coletados de servidores DNS públicos.
- Informações coletadas dos certificados SSL / TLS do site.

Embora as fontes listadas anteriormente e discutidas com mais detalhes neste tópico sejam de grande valor para a coleta do OSINT, você também pode achar útil pesquisar informações públicas usando vários padrões do setor. Por exemplo, as seguintes fontes de ameaças e de inteligência sobre vulnerabilidade reconhecidas pela indústria são mantidas pelo MITRE Corporation, que recebe financiamento do Departamento de Segurança Interna dos EUA:

- Vulnerabilidades e exposições comuns (CVE): um dicionário de vulnerabilidades.
- Enumeração de fraqueza comum (CWE): um banco de dados de vulnerabilidades relacionadas a software.
- Enumeração e classificação de padrão de ataque comum (CAPEC): um banco de dados que classifica padrões de ataque específicos.

Outra fonte potencial de pesquisa está em uma ou mais importantes equipes de resposta a emergências de computadores (CERTs), como o Centro de Coordenação CERT (CERT/CC), a Equipe de Prontidão de Emergência em Computadores dos EUA (US-CERT) e a Coordenação de Equipe de Resposta a Emergências de Computadores do Japão Centro (JPCERT/CC).

Esses CERTs geralmente emitem avisos de segurança pública que contêm informações úteis sobre uma ampla gama de vulnerabilidades.

Organizações de padrões, como a Organização Internacional de Padronização (ISO) e o Instituto Nacional de Padrões e Tecnologia (NIST), também podem ser fontes valiosas de informação pública. Por exemplo, o NIST, uma agência governamental dos EUA, publica muitos documentos que detalham questões de segurança conhecidas e orientações para as organizações sobre como mitigá-las.

Finalmente, você deve estar atento a instâncias de divulgação completa. **Full disclosure** é o processo de publicação de uma análise de vulnerabilidades sem restrições sobre quem pode acessar essa análise.

A intenção é garantir que o maior número possível de usuários e organizações esteja ciente das vulnerabilidades, para que estes possam tomar medidas para se protegerem. No entanto, o efeito colateral da divulgação completa é que os invasores também têm acesso a essas informações e podem agir de acordo com elas. Como pentest, uma instância de divulgação completa pode fornecer informações valiosas sobre uma parte vulnerável da tecnologia usada pela organização de destino.

2 CONSULTANDO WHOIS

2.1 Presença web

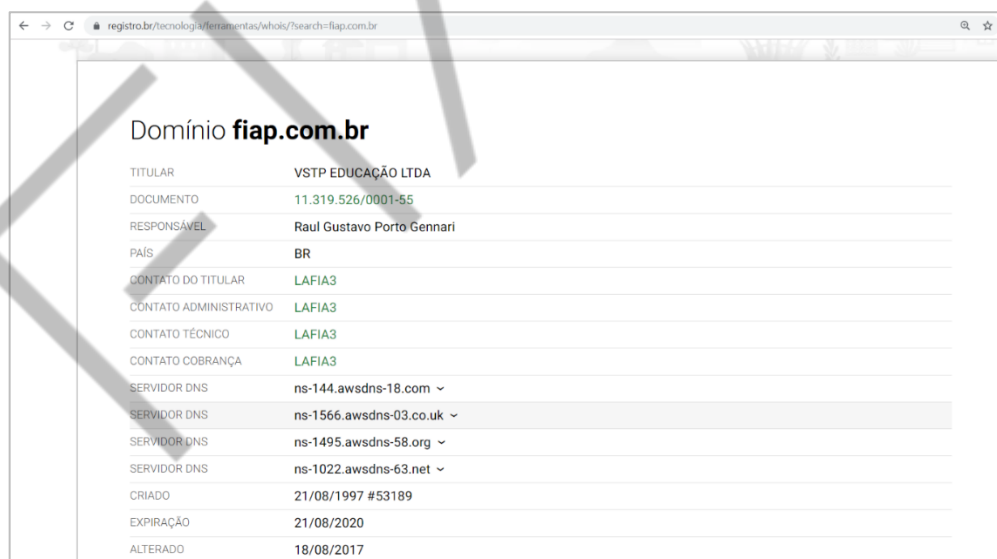
Whois é um protocolo que suporta a consulta de dados relacionados a entidades que registram domínios públicos e outros recursos da Internet. As informações sobre essas entidades estão disponíveis para quem consulta bancos de dados usando o Whois. Uma consulta Whois pode ser executada usando um utilitário de linha de comando, mas também existem aplicativos da Web disponíveis que permitem que os usuários executem consultas. Uma consulta típica será realizada em um domínio público, como o fiap.com.br, para revelar informações sobre esse domínio e, por sua vez, a organização que o possui.

Consultas Whois pode recuperar informações como:

- Nome do registrante do domínio.

- Nome da organização registrante.
- Endereço para correspondência do registrante.
- Número de telefone do registrante.
- Endereço de e-mail do registrante.
- Informações anteriores sobre contatos administrativos e técnicos.
- Identificação de informações sobre o registrador do domínio.
- Status do domínio, incluindo códigos de cliente e servidor que dizem respeito a renovação, exclusão, transferência e informações relacionadas.
- Servidores de nomes que o domínio usa.

As consultas Whois são uma ótima ferramenta para o OSINT, pois podem lhe dizer muito sobre a organização de destino e como seu domínio está configurado. Você pode usar essas informações para executar ações mais direcionadas contra os contatos do domínio, bem como a arquitetura subjacente do domínio. Veja, na Figura “Whois”, um exemplo do domínio fiap.com.br.



Domínio fiap.com.br	
TITULAR	VSTP EDUCAÇÃO LTDA
DOCUMENTO	11.319.526/0001-55
RESPONSÁVEL	Raul Gustavo Porto Gennari
PAÍS	BR
CONTATO DO TITULAR	LAFIA3
CONTATO ADMINISTRATIVO	LAFIA3
CONTATO TÉCNICO	LAFIA3
CONTATO COBRANÇA	LAFIA3
SERVIDOR DNS	ns-144.awsdns-18.com ▾
SERVIDOR DNS	ns-1566.awsdns-03.co.uk ▾
SERVIDOR DNS	ns-1495.awsdns-58.org ▾
SERVIDOR DNS	ns-1022.awsdns-63.net ▾
CRIADO	21/08/1997 #53189
EXPIRAÇÃO	21/08/2020
ALTERADO	18/08/2017

Figura 1 - Whois
Fonte: Elaborada pelo autor (2019)

Os sites de marketing geralmente fornecem as seguintes informações, que podem ser úteis para o pentest:

- Preenchimento de dados para receber mais informações sobre produtos e serviços que a organização oferece.

- Fóruns de usuários e outro conteúdo direcionado à comunidade.
- A informação de contato adicional além do que você encontraria em uma consulta Whois.
- Links para os perfis de mídia social da organização.
- Uma lista de executivos de alto escalão, alta gerência ou outras pessoas de alto nível na organização.
- Próximos eventos organizados ou assistidos pela organização.

O principal site público de uma organização não será, necessariamente, um site de marketing padrão. Por exemplo, o domínio mais público da Amazon é uma loja on-line. Organizações governamentais e instituições educacionais podem hospedar sites puramente informativos. O que você coletará no site público de uma organização depende de qual organização você está segmentando e, além disso, você nunca deve esperar aprender tudo o que é possível somente nesse site.

O site principal de uma organização para consumo público não é o único site que pode ajudá-lo a reunir informações básicas sobre a organização. A seguir, estão outros sites em potencial, que podem revelar informações acionáveis:

- Sites secundários, como aqueles destinados ao uso por funcionários ou clientes específicos em um cenário de vendas entre empresas.
- Subdomínios de sites primários que não estão diretamente vinculados ou que são facilmente visíveis no site primário, como portais administrativos.
- Sites de propriedade e/ou operados por organizações parceiras, como um fornecedor com o qual um fornecedor de varejo geralmente contrata.
- Sites das subsidiárias da organização alvo ou, inversamente, a organização pai do alvo.
- Perfis de mídia social que são usados como outro meio de marketing (ou talvez primário) da organização.

Embora um site relacionado possa não fornecer o mesmo nível de OSINT que o site principal, ele ainda pode fornecer detalhes adicionais que você não obteria de outra forma. Um site de parceiro pode revelar mais sobre o relacionamento do parceiro

com a organização de destino, possivelmente o suficiente para você tentar usar o parceiro como um vetor (supondo que isso esteja dentro do escopo).

2.1.1 Mídias sociais

A maioria das organizações que fornecem produtos e serviços ao público – e mesmo aqueles que não o fazem – tem pelo menos alguma presença nas mídias sociais. Esses perfis de mídia social são usados, principalmente, como um canal de marketing para atingir determinados públicos que podem não estar expostos ao marketing tradicional. De fato, muitos clientes em potencial talvez nunca vejam o site principal da organização, portanto, uma organização pode colocar muito esforço em sua presença nas mídias sociais. Deste modo, você poderá coletar uma grande quantidade de informações sobre como o destino faz negócios.

Além do perfil da organização, a mídia social também é um recurso rico para extrair dados sobre indivíduos. Todos, desde o nível C até os funcionários de nível médio, podem estar presentes em vários sites de mídia social. Esses perfis individuais geralmente são vinculados ao perfil principal da empresa, facilitando o reconhecimento da estrutura de pessoal de uma organização.

Da mesma forma, um indivíduo pode ter mais de um perfil para separar sua vida profissional e sua vida pessoal. Em ambos os casos, os perfis individuais podem revelar muito sobre os interesses, hábitos, comportamento, relacionamentos e outras PII de um funcionário.

Exemplos de sites de mídia social comuns que podem fornecer inteligência acionável incluem:

- Twitter: usado por muitas organizações para promover seus produtos e serviços em breves declarações, além de fornecer atendimento casual ao cliente e reforçar a lealdade e o reconhecimento da marca.
- Facebook: usado para um marketing mais aprofundado e com maior probabilidade de incluir imagens, vídeos e agendamento de eventos.
- LinkedIn: usado principalmente para oportunidades de rede e procura de emprego.

- YouTube: usado para publicar vídeos que comercializam produtos, serviços e/ou marca de uma organização.
- Instagram: usado para publicar imagens que comercializam produtos, serviços e/ou marca de uma organização.
- Reddit: que geralmente é usado para direcionar esforços de marketing para comunidades específicas.

As organizações que desejam contratar, geralmente publicam em quadros públicos de empregos. Essas ofertas de emprego podem revelar informações sobre a estrutura de pessoal da organização, ambientes técnicos, arquitetura de rede e outras infraestruturas de computação. Isso ocorre porque o empregador precisa atrair os funcionários em potencial e fornecer informações suficientes para determinar se eles devem ou não se aplicar. A quantidade e o tipo de informações nessas ofertas de emprego são altamente dependentes do setor da organização e do trabalho real para o qual estão contratando. Uma posição de administrador de rede para uma empresa de tecnologia pode incluir mais informações sobre o lado técnico das operações da organização do que uma posição de associado de vendas em um negócio de varejo.

Algumas informações que você pode coletar dos quadros de tarefas incluem:

- Composição do pessoal de departamentos e equipes específicos.
- Falta de pessoal qualificado em posições cruciais.
- Nível de sofisticação técnica que a organização possui.
- Arquitetura de software dos serviços técnicos da organização, como tecnologia de servidor da web e tecnologias em nuvem.
- Idioma em que o software interno está programado.
- Tipos e quantidades de hardware que a organização emprega.
- Sistemas de rede e segurança que a organização emprega. Alguns quadros de empregos públicos comuns incluem: CareerBuilder, Monster, ZipRecruiter, De fato, Glassdoor e LinkedIn.

3 GOOGLE HACKING E DNS

Hacking no Google é o processo de usar o mecanismo de busca do Google para identificar possíveis deficiências de segurança em fontes publicamente disponíveis, como o site de uma organização. Embora não seja necessariamente "hacking", em sentido direto, o mecanismo de pesquisa do Google permite extrair mais informações do que seria possível em uma pesquisa diária comum.

As consultas de hackers do Google quase sempre incluem um operador de pesquisa especial para reduzir resultados irrelevantes e se concentrar em tipos muito específicos de informações desejadas. O Quadro "Google hacking" lista alguns operadores de pesquisa especiais comuns que são frequentemente usados no Google hacking.

Operador	Pesquisas	Exemplo
site	Um site específico.	site: fiap.com.br NEXT para pesquisar no site da FIAP apenas resultados, incluindo o texto "NEXT".
link	Para páginas que apontam para a página especificada.	link: fiap.com.br NEXT para procurar por páginas que apontam para o site da FIAP e ter o texto "NEXT" em qualquer lugar da página.
filetype	Para tipos de arquivos específicos.	filetype: pdf para pesquisar PDFs.
intitle	Para títulos de página.	intitle: NEXT para procurar por páginas cujos títulos incluem o texto "NEXT".
inurl	Para URLs.	inurl: NEXT para procurar por páginas cujos URLs incluem o texto "NEXT".
inanchor	Para texto âncora.	inanchor: NEXT para procurar páginas cujo texto âncora inclua o texto "NEXT".

Quadro 1 – Google hacking
Fonte: Elaborado pelo autor (2020)

A consulta de servidores DNS para obter informações sobre resolução de nomes pode permitir que você veja mais sobre a estrutura da rede de uma organização. As consultas padrão simplesmente usarão servidores DNS para identificar o endereço IP por trás de um domínio ou nome de recurso específico. Esse endereço IP pode ser útil como ponto de entrada na rede ou, possivelmente, como vetor para realizar mais reconhecimento.

As consultas avançadas podem recuperar mais informações do que apenas um endereço IP. Você pode identificar os registros DNS individuais de um domínio específico, como registros MX, NS, TXT e mais. Esses registros conseguem revelar destinos adicionais que você pode não ter enumerado usando outros métodos OSINT.

Por exemplo, você pode identificar que a organização está usando serviços específicos, como VoIP, enumerando um registro SRV.

Existem várias ferramentas que podem ajudar a realizar consultas DNS, incluindo vários aplicativos da web. Uma ferramenta de linha de comando comum é o `nslookup`, que você pode usar para consultar um domínio e especificar os tipos de registro que estiver procurando. A escavação da ferramenta tem uma funcionalidade semelhante, é mais amplamente usada nos sistemas Linux e pode executar pesquisas inversas para corresponder um endereço IP a um nome de domínio.

Além de identificar registros DNS, você também poderá usar a consulta DNS para iniciar uma transferência de zona. Em um ambiente configurado corretamente, as informações de um servidor DNS serão transferidas para outros servidores DNS no mesmo domínio, para fins de *backup*. No entanto, servidores configurados incorretamente podem vaziar essas informações para hosts fora do domínio, incluindo o seu. Essas informações não podem apenas revelar registros DNS, mas também enumerar quais hosts estão diretamente acessíveis na Internet.

Um dos elementos mais úteis das informações de contato que você pode reunir é um endereço de e-mail, já que este é o principal ponto de contato interno e externo de muitas pessoas em muitas organizações. Também é um vetor comum para solicitar informações sobre pessoas e organizações, além de ataques de engenharia social mais intrusivos. Os endereços de e-mail também são comumente usados no lugar de nomes de usuário em sistemas que gerenciam contas de usuário. Isso pode facilitar o foco de seus ataques de quebra de senha on-line ou outras técnicas para obter acesso não autorizado.

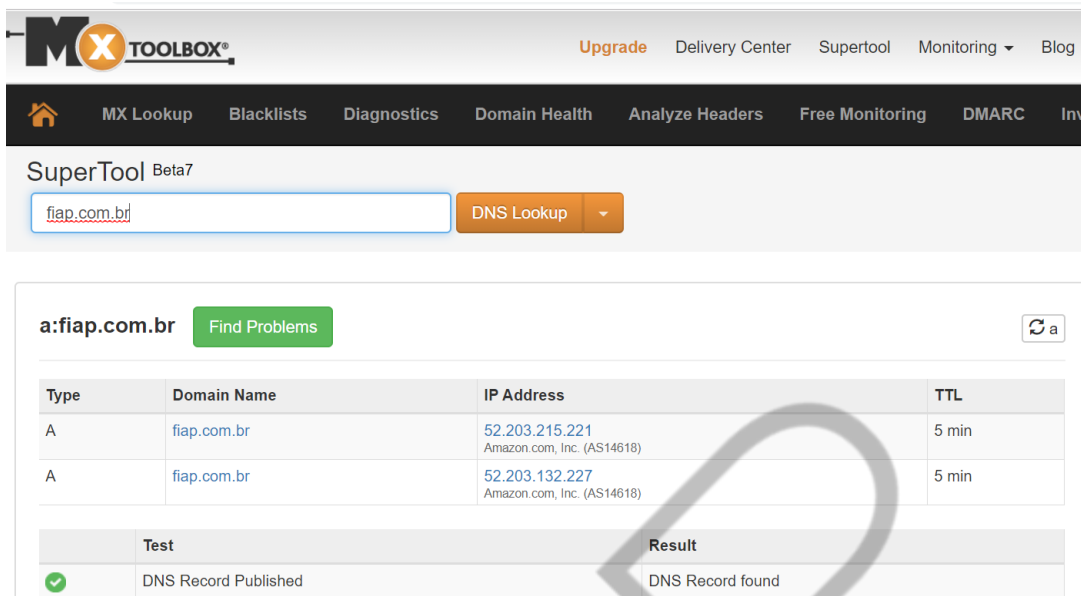
Além dos endereços de e-mail, considere também enumerar os registros DNS baseados em e-mail. Um registro MX informará qual servidor gerencia as mensagens enviadas para esse domínio. Se você puder comprometer com êxito, os servidores de e-mail poderão comprometer efetivamente as linhas de comunicação dentro do domínio.

Outro registro DNS digno de nota é o Sender Policy Framework (SPF). O SPF valida que as mensagens recebidas de um domínio são provenientes de um endereço IP confiável. Esse é um esforço para reduzir a falsificação de e-mail usada em spam, phishing e outros ataques baseados em e-mail. Para o pentest, identificar a presença de um registro SPF pode encorajá-lo a não perder tempo com mensagens falsas.

Como alternativa, você pode concentrar seus esforços em direcionar o host com o endereço IP confiável identificado no registro.

Os certificados digitais usados nas comunicações SSL/TLS são outro recurso público que pode informar suas ações de pentest. Um dos campos mais úteis em um certificado digital da perspectiva do reconhecimento é o nome alternativo do assunto (SAN). As SANs geralmente identificam subdomínios específicos aos quais o certificado se aplica, mas também podem identificar outros domínios, endereços IP e de e-mail. As organizações usam SANs em seus certificados para que não precisem comprar e usar certificados diferentes para cada recurso individual. Os recursos identificados em uma SAN podem revelar novos destinos para você se concentrar. Observe que alguns certificados simplesmente usam um caractere curinga (*) para indicar que todos os subdomínios do domínio pai estão cobertos pelo certificado. Nesse caso, talvez você não consiga identificar nenhum recurso específico.

Além das SANs, na estrutura de Transparência de certificados (CT), os *logs* das autoridades de certificação públicas (CAs) são divulgados para qualquer pessoa acessar. Esses logs contêm informações sobre os domínios e subdomínios aos quais os certificados emitidos pela CA se aplicam. Isso pode permitir que você descubra subdomínios que podem não estar mais cobertos pelo certificado, mas ainda existem. Por exemplo, uma organização pode ter usado uma SAN específica no passado, mas depois foi movida para um curinga. Esse domínio anterior pode estar listado nos *logs* do CT da CA de emissão. Vejamos, na Figura “DNS”, a ideia da consulta DNS do domínio fiap.com.br, utilizando a ferramenta mxtoolbox.



The screenshot shows the MX Toolbox SuperTool interface. At the top, there's a navigation bar with links like 'Upgrade', 'Delivery Center', 'Supertool', 'Monitoring', and 'Blog'. Below this is a dark navigation bar with links like 'MX Lookup', 'Blacklists', 'Diagnostics', 'Domain Health', 'Analyze Headers', 'Free Monitoring', 'DMARC', and 'Inv'. The main section is titled 'SuperTool Beta7' and features a search bar with 'fiap.com.br' entered and a 'DNS Lookup' button. Below the search bar, there's a section for 'a:fiap.com.br' with a 'Find Problems' button. A table displays DNS records for 'fiap.com.br' with columns for Type, Domain Name, IP Address, and TTL. Below the table, there's a 'Test' section showing 'DNS Record Published' and 'DNS Record found'.

Type	Domain Name	IP Address	TTL
A	fiap.com.br	52.203.215.221 Amazon.com, Inc. (AS14618)	5 min
A	fiap.com.br	52.203.132.227 Amazon.com, Inc. (AS14618)	5 min

Test	Result
✓ DNS Record Published	DNS Record found

Figura 2 – DNS
Fonte: Elaborada pelo autor (2019)

4 SHODAN

O Shodan é um mecanismo de pesquisa on-line que permite a qualquer pessoa se conectar a dispositivos públicos ou protegidos incorretamente, que permitem acesso remoto pela Internet. Por exemplo, um zoológico pode configurar uma câmera IP em um de seus compartimentos para que qualquer pessoa no mundo observe os animais apenas pelo navegador. Shodan indexaria essa conexão e permitiria que qualquer pessoa a procurasse. Ele faz isso pegando banners de serviço enviados por um dispositivo para um cliente em determinadas portas.

Mais comumente, no entanto, os fabricantes e os usuários de dispositivos utilizam práticas inadequadas de segurança e expõem seus dispositivos ao mundo inteiro sem querer. Por exemplo, alguém pode comprar uma câmera IP para usar como vigilância em sua casa ou escritório e pode não conseguir alterar o nome de usuário e a senha padrão de "admin" e "admin123". Usando Shodan, qualquer pessoa pode encontrar e assistir ao feed ao vivo dessa câmera, se estiver conectada à Internet.

Os dispositivos indexados pela Shodan incluem mais do que apenas câmeras, no entanto. Tudo, de semáforos a sistemas de controle industrial (ICSs), pode ter conectividade com a Internet como parte da Internet das Coisas (IoT) – e os

dispositivos IoT são notoriamente relaxados no que diz respeito à segurança. Alguns sistemas podem até permitir ao usuário o controle remoto total de um dispositivo.

Shodan pode ser útil para a fase de reconhecimento do pentest, de várias maneiras. Se você conseguir visualizar o feed de uma câmera de segurança fora do escritório da organização de destino, poderá obter uma imagem melhor das instalações e de suas defesas, se planeja realizar um teste físico local. Se a organização empregar sistemas de controle para HVAC ou equipamento industrial, você poderá controlá-los remotamente como parte de sua fase de ataque.

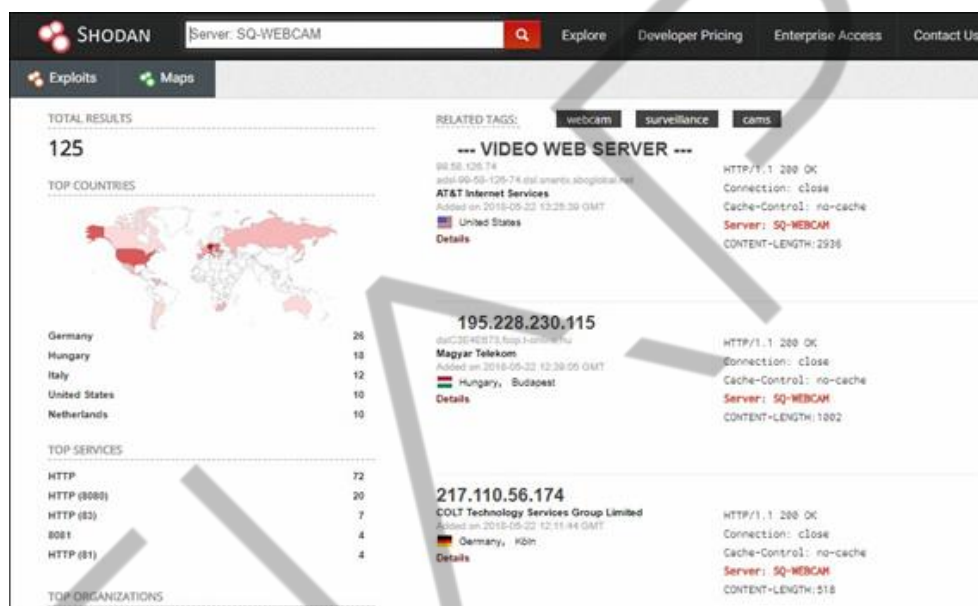


Figura 3 – Shodan
Fonte: Elaborada pelo autor (2019)

theHarvester é uma ferramenta OSINT código aberto que reúne as seguintes informações sobre um recurso público:

- Nomes de subdomínio.
- Nomes de funcionários.
- Endereços de e-mail.
- Entradas de chave PGP.
- Abrir portas e banners serviço.

Para alguns de seus dados, como nomes de funcionários e chaves PGP, theHarvester usa mecanismos de pesquisa gerais, como Google e Bing, para coletar informações. Ele também pesquisa informações de certificado diretamente do

mecanismo de pesquisa de certificados do Comodo. Para obter informações adicionais, o Harvester pesquisa sites de mídia social, como o Twitter e o LinkedIn. Sua funcionalidade de captura de banner depende do Shodan. A ferramenta é relativamente simples de usar, mas pode ajudar a automatizar muitas das tarefas de coleta de informações discutidas anteriormente.

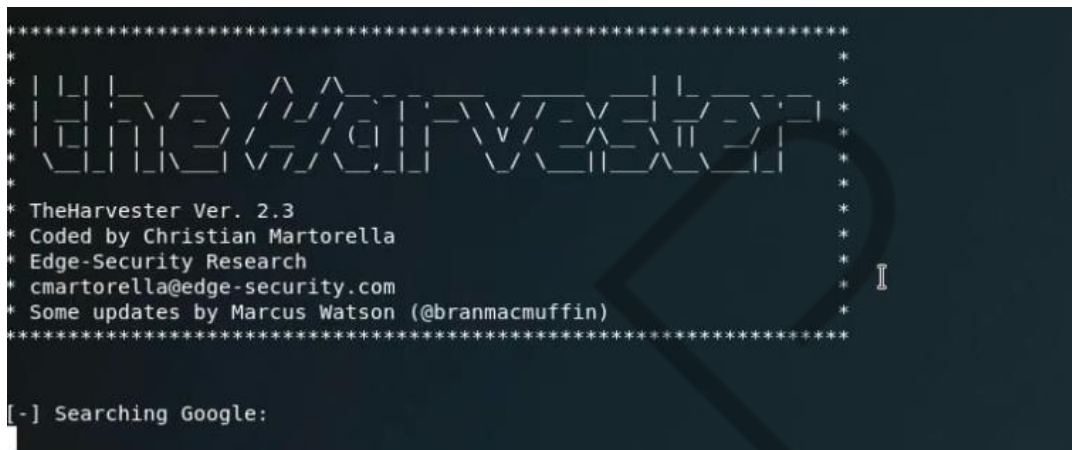


Figura 4 – theharvester
Fonte: Elaborada pelo autor (2019)

Vamos utilizar o Harvester, ela é capaz de enumerar contas de e-mail, nomes de usuários, domínios e nomes de host. Podemos executar o seguinte comando para recuperar informações:

```
thearvester -d fiap.com.br -l 100 -b google
```

- -d: domínio.
- -l: limita os resultados ao valor especificado.
- -b: as fontes de dados. (Ou seja, você pode definir Bing, Google, LinkedIn, etc.).

O Recon-ng é semelhante ao Harvester, por ser uma ferramenta de código aberto para a coleta de dados OSINT. No entanto, o Recon-ng é um pouco mais robusto e inclui dezenas de "módulos" diferentes. Cada módulo executa um tipo específico de consulta e permite definir várias opções que são necessárias ou opcionais para executar essa consulta.

Alguns módulos incluem:

- Consulta Whois para identificar pontos de contato, incluindo nomes e endereços de e-mail.

- Pesquisa de endereço de e-mail na caixa de diálogo Fui pwned? banco de dados, indicando que a conta pode ter sido associada a uma violação recente.
- Pesquisa de chave PGP.
- Associações de perfis de mídia social.
- Rastreador Arquivo.
- DNS recenseador registro e muito mais.

Maltego é outra ferramenta OSINT que pode reunir uma grande variedade de informações sobre recursos públicos. Ao contrário do Harvester e do Recon-ng, o Maltego possui uma GUI completa para ajudar os usuários a visualizarem as informações coletadas e compará-las com outros conjuntos de informações. Possui uma extensa biblioteca de "transformações", que automatiza a consulta de fontes públicas de dados.

Alguns tipos de OSINT que essas transformações enumeram incluem:

- Nomes das pessoas.
- Números de telefone de pessoas e empresas.
- Endereços físicos de pessoas e empresas.
- Blocos de endereço de rede.
- Endereços de e-mail.
- Ligações externas.
- Registros DNS.
- Subdomínios.
- Os arquivos para download.
- Perfis de mídia social e muito mais.

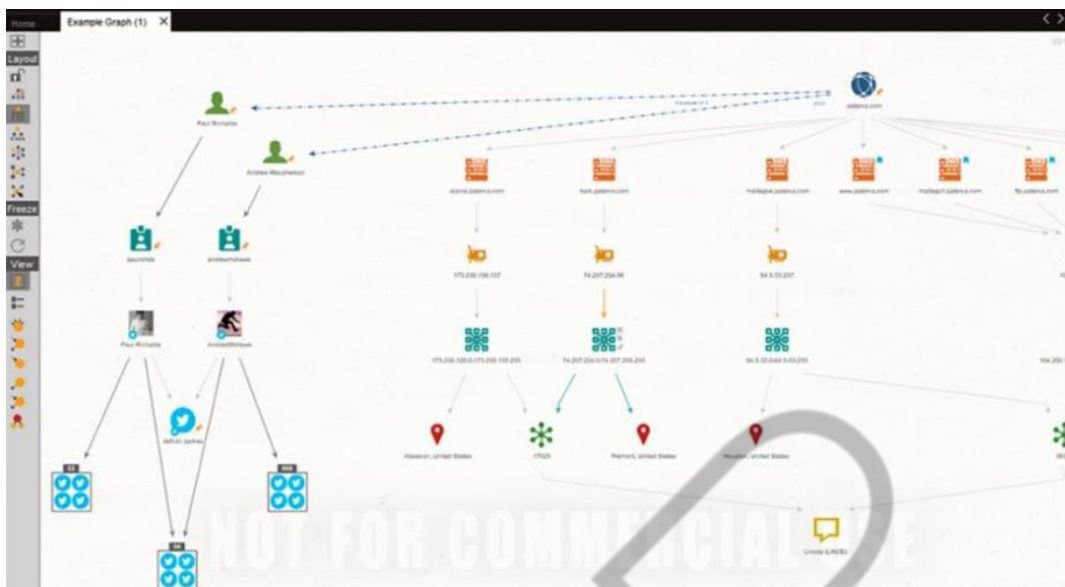


Figura 5 – Maltego
Fonte: Elaborada pelo autor (2019)

Os resultados da consulta são colocados nos gráficos dos nós, em que os vínculos são estabelecidos entre cada nó. Isso permite ao usuário analisar como dois ou mais pontos de dados podem ser conectados. Por exemplo, se você executar uma transformação em um domínio, o Maltego poderá colocá-lo no topo de uma hierarquia de árvore com vários links de ramificação para outros recursos nesse domínio, como subdomínios enumerados pelo DNS. Sob esses subdomínios, pode haver endereços IP e intervalos de endereços. Em uma pesquisa mais orientada para as pessoas, os recursos que ramificam o domínio podem incluir números de telefone pessoais, endereços de e-mail etc. O Maltego fornece mais do que apenas *layouts* hierárquicos, você também pode mostrar objetos em um *layout* circular, *layout* de bloco, *layout* orgânico (distância mínima entre entidades) e muito mais.

Observe que o Maltego é um software proprietário e vem em várias edições. O Maltego CE é a edição gratuita, entretanto requer que você se registre em uma conta da Comunidade Maltego para aproveitar um conjunto limitado de transformações disponíveis.

Fingerprinting Organizations with Collected Archives (FOCA) é uma ferramenta da GUI OSINT projetada principalmente para descobrir metadados úteis que podem estar ocultos nos documentos, geralmente aqueles baixados da web. O FOCA pode trabalhar com vários tipos de documentos, incluindo o Microsoft Office (.docx, .xlsx etc.) e o formato OpenDocument (.odt, .ods etc.).

Ele também pode analisar PDFs e tipos de arquivos de design gráfico, como o formato Scalable Vector Graphics (SVG) baseado em XML.

Como com muitas das ferramentas mencionadas anteriormente, o FOCA verifica os mecanismos de pesquisa gerais como Google, Bing e DuckDuckGo para encontrar arquivos para download. Você também pode fornecer arquivos locais para o FOCA analisar. Alguns dos metadados úteis que o FOCA pode extrair incluem nomes de usuários e pessoas, informações sobre a versão do software, informações sobre a versão do sistema operacional, informações sobre a impressora, senhas em texto sem formatação e muito mais.

A funcionalidade da FOCA expandiu-se ao longo dos anos a ponto de não apenas fazer extração de metadados, mas também pode funcionar como uma ferramenta OSINT geral. Ele pode coletar informações de endereço IP e DNS, e sua arquitetura de plug-in permite que os desenvolvedores ampliem ainda mais sua funcionalidade. Observe que, diferentemente do Harvester, Recon-ng e Maltego, o FOCA é uma ferramenta somente para Windows. Também requer um servidor SQL em execução para armazenar seus dados em um banco de dados.

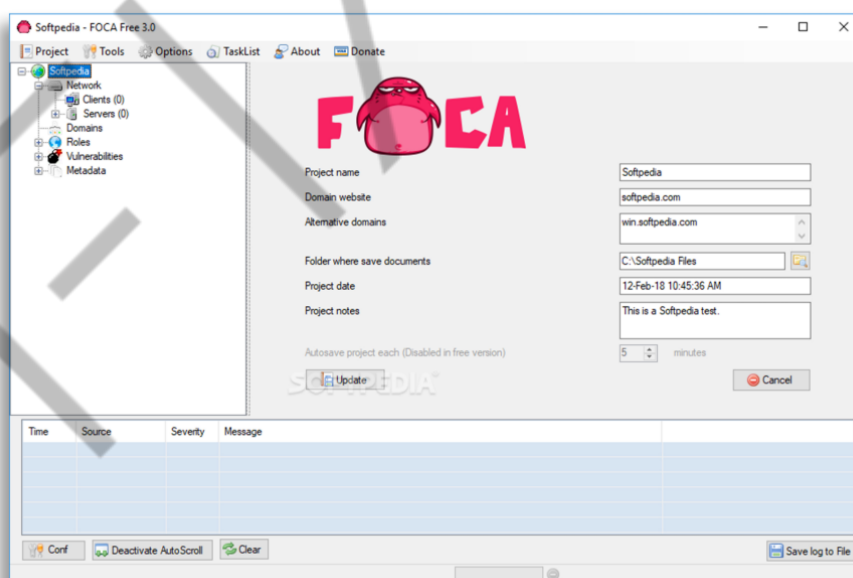


Figura 6 – FOCA
Fonte: Elaborada pelo autor (2019)

REFERÊNCIAS

KENNEDY, D.; O'GORMAN, J.; KEARNS D. **Metasploit**: The Penetration Tester's Guide. San Francisco, California: No Starch Press, 2011.

WEIDMAN, G. **Penetration Testing**: A Hands-On Introduction to Hacking. San Francisco, California: No Starch Press, 2014

WILHELM, T. **Professional Penetration Testing**: Creating and Learning in a Hacking Lab. 2. Waltham, MA: Syngress, 2013.

EXEMPLO